

Lynx Ransomware Incident Response Report

Date Range: 2025-03-01 to 2025-03-09

Table of Contents

1. [Executive Summary](#)
 2. [Detailed Findings](#)
 - [Initial Access](#)
 - [Lateral Movement and Discovery](#)
 - [Exfiltration](#)
 - [Payload Deployment](#)
 - [Threat Group Assessment](#)
 3. [Conclusion and Recommendations](#)
 4. [Appendix - Timeline](#)
 5. [Appendix - Additional Technical Details](#)
 6. [Evidence Gaps](#)
-

Executive Summary

The Lynx ransomware incident was initiated via repeated Remote Desktop Protocol (RDP) brute-force attacks targeting the internal host 10.128.239.57 over multiple days. Successful logins were observed from several distinct external attacker IPs, none of which matched the brute-force source IPs, indicating credential compromise and reuse. The attacker established persistent access through long-duration RDP sessions, with the largest session exceeding 29 million bytes and lasting over an hour.

Following initial access, the attacker leveraged SMB administrative shares and remote service creation via Distributed Component Object Model (DCOM) and Windows Management Instrumentation (WMI) to move laterally across the internal network. No evidence of RDP-based lateral movement was conclusively observed, likely due to capture limitations. Extensive user and group enumeration via DCE/RPC SAMR calls was detected, consistent with reconnaissance and privilege escalation attempts.

No confirmed data exfiltration was detected during the investigation. The ransomware payload deployment relied primarily on SMB file transfers of executables and archives from the patient zero host (10.128.239.57) to multiple internal hosts, followed by remote execution via DCOM remote activation to launch the ransomware. No suspicious HTTP payload downloads or RDP-based payload deployment were observed.

The attack aligns with known techniques used by multiple advanced threat groups, with the highest technique overlap observed with APT32 and BlackByte ransomware groups. However, insufficient evidence exists to conclusively attribute the attack to a specific group.

Business Impact:

- Compromise of multiple internal hosts (at least six confirmed)
- Potential exposure of sensitive data and operational disruption due to ransomware deployment
- Persistent attacker presence for over a month, indicating significant risk to enterprise security

Recommendations:

- Immediate containment and credential resets on all compromised hosts
- Restrict and monitor SMB administrative share access and DCOM/WMI remote execution activities
- Enhance logging and monitoring for NTLM and Kerberos authentication to detect credential abuse
- Harden RDP exposure and implement multi-factor authentication
- Conduct thorough endpoint and network forensic investigations to identify and remediate persistence mechanisms

Detailed Findings

Initial Access

Technique ID	Technique Name	Description	Evidence	Confidence	Notes
T1110	Brute Force	Repeated attempts to gain access via password guessing	Multiple brute-force RDP attempts from 300+ external IPs targeting 10.128.239.57 on port 3389	High	Brute-force attempts exceeded 300,000 over multiple days
T1078.002	Domain Accounts	Use of compromised domain credentials for access	Successful RDP logins from external IPs distinct from brute-force sources (e.g., 77.90.153.30, 195.211.190.189)	High	Successful sessions had large byte counts and long durations, indicating interactive access

T1021.001	Remote Desktop Protocol	Use of RDP for initial access	Successful RDP sessions to 10.128.239.57 from attacker IPs on port 3389	High	Sessions ranged from minutes to over 34 hours in duration
-----------	-------------------------	-------------------------------	---	------	---

Supporting Evidence:

- Successful RDP login from 96.126.120.149 on 2025-03-01 with 1,091,450 bytes transferred
- Successful RDP login from 216.250.247.139 on 2025-03-02 lasting ~10.6 minutes
- Successful RDP login from 195.211.190.189 on 2025-03-06 lasting over 34 hours with 1.6 million bytes
- Successful RDP login from 77.90.153.30 on 2025-03-08 with 29.5 million bytes transferred
- Brute-force IPs include 141.98.11.170, 179.60.146.33, 149.50.116.107, 196.119.122.241, among others
- No evidence of pre-existing compromise at capture start, but DNS queries to tacticalrmm.io indicate active RMM infrastructure

Assumptions & Limitations:

- Exact session start/end times for some RDP sessions are not precisely extracted
- Some brute-force attempts may have been missed due to capture scope

Lateral Movement and Discovery

Technique ID	Technique Name	Description	Evidence	Confidence	Notes
T1021.002	SMB/ Windows Admin Shares	Use of SMB shares for lateral movement and file operations	SMB file operations and admin share (IPC\$) accesses between compromised hosts	High	Multiple hosts accessed admin shares on domain controllers and internal hosts
T1021.003	Distributed Component Object Model	Remote service creation and execution via DCOM	Numerous DCOM remote activation events targeting 10.128.239.32 and other hosts	High	Remote execution events consistent with lateral movement
T1087	Account Discovery	User and group enumeration via SAMR RPC calls	Extensive SAMR enumeration from hosts like 10.128.239.140 to 10.128.239.20	High	Reconnaissance activity to identify targets and escalate privileges

T1021.001	Remote Desktop Protocol	RDP sessions observed internally for lateral movement (limited)	Some RDP sessions from 10.128.239.57 to internal hosts (e.g., 10.128.239.64, 10.128.239.65)	Medium	RDP lateral movement observed on 2025-03-02, but limited evidence overall
-----------	-------------------------	---	---	--------	---

Supporting Evidence:

- SMB file operations from 10.128.239.57 to 10.128.239.23 and 10.128.239.20
- DCOM remote activations (IRemoteSCMAActivator) from multiple compromised hosts to 10.128.239.32
- SAMR user/group enumeration from 10.128.239.140 and 10.128.239.79 to other hosts
- RDP sessions from 10.128.239.57 to 10.128.239.64 and 10.128.239.65 with active user cookies
- No NTLM pass-the-hash or Kerberos ticket abuse detected due to missing or limited data

Assumptions & Limitations:

- NTLM authentication analysis incomplete due to missing PCAP path
- RDP lateral movement detection limited by capture scope and logging gaps
- Kerberos anomalies inconclusive, no clear pass-the-ticket or kerberoasting observed

Exfiltration

Technique ID	Technique Name	Description	Evidence	Confidence	Notes
N/A	No exfiltration detected	No evidence of data exfiltration observed	None	Low	No outbound spikes; no large HTTP POSTs; no compression indicators

Supporting Evidence:

- No outbound spikes to file-sharing services such as temp.sh
- No large HTTP POST transfers detected
- No compression magic bytes (e.g., 7-Zip) observed in network traffic

Payload Deployment

Technique ID	Technique Name	Description	Evidence	Confidence	Notes
T1021.002	SMB/Windows Admin Shares	SMB file transfers of ransomware payloads	Multiple SMB file drops of executables and archives from 10.128.239.57 to internal hosts	High	Files include SETUP.EXE, arrestees.zip, ChromeSetup.exe, among others
T1021.003	Distributed Component Object Model	Remote execution via DCOM remote activation	Numerous DCOM remote activation events targeting 10.128.239.32 and others	High	Remote service creation used to execute payloads
T1021.001	Remote Services (DCOM, WMI)	Remote execution via DCOM and WMI	WMI login and remote query events from 10.128.239.82 to 10.128.239.20	Medium	WMI used for lateral movement and execution
T1047	Windows Management Instrumentation	Use of WMI for execution	WMI remote query and login events detected	Medium	Supports remote execution and lateral movement

Supporting Evidence:

- SMB file drop of UninstallWinClient.exe from 10.128.239.57 to 10.128.239.66 (2025-03-08T09:06:19.788Z)
- SMB file drops of multiple executables and archives to hosts 10.128.239.34, 10.128.239.176, 10.128.239.36, 10.128.239.32
- 21 DCOM remote activation events targeting 10.128.239.32 from multiple compromised hosts
- WMI remote login and query events from 10.128.239.82 to 10.128.239.20
- No RDP sessions from domain controllers or compromised hosts for payload deployment
- No suspicious HTTP payload downloads; one zero-byte HTTP download observed, likely unrelated

Assumptions & Limitations:

- No direct executable or archive file hashes available for confirmation
 - No evidence of RDP-based payload deployment or external HTTP downloads
 - Remote execution events inferred from DCOM and WMI logs
-

Threat Group Assessment

Threat Group	Overlap Count	Matching Techniques Summary	Likelihood Assessment
APT32	14	Extensive use of SMB, DCOM, WMI, brute force, credential access, lateral movement, and exfiltration techniques	High - Strong technique overlap with observed TTPs
BlackByte	13	Ransomware group with SMB, RDP, remote execution, brute force, and credential access techniques	High - Matches ransomware payload deployment and initial access methods
Chimera	12	Similar lateral movement and credential access techniques	Medium - Partial overlap, less direct ransomware association
Wizard Spider	11	Financially motivated group with similar lateral movement and credential access techniques	Medium - Overlap in lateral movement and initial access, but less payload detail
OilRig	11	Credential access and lateral movement techniques	Medium - Overlap in brute force and lateral movement, no ransomware focus
APT39	11	Credential access and lateral movement techniques	Medium - Similar TTPs but less ransomware focus
APT41	11	Broad espionage and financially motivated group with lateral movement and credential access	Medium - Partial overlap, no direct ransomware attribution
Ember Bear	9	Russian espionage group with credential access and lateral movement	Low - Less overlap with ransomware-specific TTPs
APT28	9	Russian espionage group with credential access and lateral movement	Low - Less overlap with ransomware-specific TTPs
Lazarus Group	9	North Korean group with credential access and lateral movement	Low - Less overlap with ransomware-specific TTPs

Interpretation: The attack techniques strongly align with ransomware groups leveraging brute-force RDP access, SMB lateral movement, and remote execution via DCOM/WMI. APT32 and BlackByte show the highest overlap with observed techniques, suggesting these groups as plausible candidates. However, no definitive attribution can be made due to overlapping TTPs among multiple groups and lack of unique indicators.

Conclusion and Recommendations

Summary

The Lynx ransomware attack was initiated via brute-force RDP attacks leading to successful logins from multiple external IPs. The attacker established persistent access and moved laterally using SMB administrative shares and remote execution via DCOM and WMI. The ransomware payload was deployed primarily through SMB file transfers and remote execution, without evidence of RDP-based payload deployment or external HTTP downloads. No data exfiltration was detected. The attack demonstrates sophisticated use of Windows native protocols and tools for lateral movement and payload execution.

Prioritized Recommendations

Priority	Recommendation
High	Immediately contain and isolate all compromised hosts (10.128.239.20, 21, 23, 24, 29, 57)
High	Reset credentials for all affected accounts and enforce strong password policies and MFA
High	Restrict SMB administrative share access and monitor for unusual file operations
High	Monitor and block suspicious DCOM remote activation and WMI execution events
Medium	Harden RDP exposure: limit external access, enforce MFA, and monitor RDP session activity
Medium	Enhance logging and capture for NTLM and Kerberos authentication to detect credential abuse
Medium	Investigate and remediate Tactical RMM infrastructure and any pre-existing compromises
Low	Conduct threat hunting for additional persistence mechanisms and lateral movement beyond capture
Low	Review and update incident response and network segmentation policies

Appendix - Timeline

Date	Event Description
2025-03-01	Initial brute-force RDP attempts targeting 10.128.239.57; successful login from 96.126.120.149
2025-03-02	Continued brute-force; successful login from 216.250.247.139; SMB lateral movement observed
2025-03-03	Internal RDP sessions from 10.128.239.57 to other hosts; lateral movement via SMB and DCE/RPC
2025-03-04	SMB file drop of script RMPGpo.wsf from 10.128.239.82 to 10.128.239.20; WinRM and WMI execution
2025-03-05	Successful RDP login from 91.238.181.39; SMB lateral movement and DCOM remote execution observed

2025-03-06	Long-duration RDP session from 195.211.190.189 to 10.128.239.57; extensive SMB and DCOM activity
2025-03-07	RDP brute-force attempts continue; no successful external login observed; lateral movement ongoing
2025-03-08	Successful RDP login from 77.90.153.30; SMB file drop of UninstallWinClient.exe; DCOM remote exec
2025-03-09	Successful RDP login from 196.119.122.241; SMB and DCOM lateral movement; no exfiltration detected

Appendix - Additional Technical Details

- **Initial Access:**
 - RDP brute-force attempts from 300+ unique external IPs targeting 10.128.239.57 on TCP 3389
 - Successful RDP sessions identified by anomalously large byte counts and durations
 - No pre-existing active C2 beaconing at capture start, but Tactical RMM DNS queries indicate existing RMM infrastructure
- **Lateral Movement:**
 - SMB file operations and admin share (IPC\$) accesses between compromised hosts (10.128.239.20, 21, 23, 24, 29, 57)
 - DCOM remote activation events (IRemoteSCMAActivator) targeting 10.128.239.32 and others
 - SAMR user/group enumeration via DCE/RPC from multiple hosts
 - Limited RDP lateral movement observed; NTLM and Kerberos analysis limited by data gaps
- **Payload Deployment:**
 - SMB file drops of multiple executables and archives from patient zero (10.128.239.57) to internal hosts
 - Remote execution via DCOM and WMI to deploy and execute ransomware payloads
 - No suspicious HTTP payload downloads or RDP-based payload deployment detected
- **Exfiltration:**
 - No evidence of data exfiltration detected
 - No outbound spikes to file-sharing services or large HTTP POSTs observed
- **Tools Used by Adversary:**
 - RDP for initial access and interactive sessions
 - SMB shares for lateral movement and payload staging
 - DCOM and WMI for remote service creation and execution

- Possible use of scripts (e.g., RMPGpo.wsf) and executables (UninstallWinClient.exe) for payload deployment
- Analyst Tools:
 - Network traffic analysis via Zeek logs and PCAP inspection
 - Correlation of SMB, DCE/RPC, Kerberos, NTLM, and HTTP logs for comprehensive view

Evidence Gaps

Gap Description	Impact on Analysis
Missing PCAP path for NTLM authentication analysis	Unable to detect pass-the-hash or credential relay
Limited RDP session metadata and logging	Partial visibility into RDP lateral movement
No file hashes or endpoint logs for payload confirmation	Cannot definitively identify ransomware binaries
Lack of detailed Kerberos anomaly detection	Uncertain about ticket abuse techniques
No endpoint or host-based logs included	Limited insight into persistence and post-exploitation activity

End of Report

Appendix: Evidence Provenance

PCAPs Analysed

Day	PCAP File	Size
2025-03-01	34936-sensor-250301-00002369_redacted.pcap	330.4 MB
2025-03-02	Copy of 34936-sensor-250302-00002374_redacted.pcap	409.0 MB
2025-03-03	Copy of 34936-sensor-250303-00002382_redacted.pcap	433.2 MB
2025-03-04	34936-sensor-250304-00002397_redacted.pcap	72.7 MB
2025-03-05	34936-sensor-250305-00002423_redacted.pcap	336.2 MB
2025-03-06	34936-sensor-250306-00002441_redacted.pcap	766.3 MB
2025-03-07	34936-sensor-250307-00002442_redacted.pcap	415.7 MB
2025-03-08	34936-sensor-250308-00002460_redacted.pcap	849.1 MB

2025-03-09	34936-sensor-250309-00002487_redacted.pcap	355.8 MB
------------	--	----------

Zeek Log Files Used

Day	Datasets
2025-03-01	zeek.connection.ndjson, zeek.dce_rpc.ndjson, zeek.dns.ndjson, zeek.http.ndjson, zeek.kerberos.ndjson, zeek.notice.ndjson, zeek.rdp.ndjson, zeek.smb_files.ndjson, zeek.smb_mapping.ndjson, zeek.ssl.ndjson, zeek.weird.ndjson
2025-03-02	(same 11 datasets)
2025-03-03	(same 11 datasets)
2025-03-04	(same 11 datasets)
2025-03-05	(same 11 datasets)
2025-03-06	(same 11 datasets)
2025-03-07	(same 11 datasets)
2025-03-08	(same 11 datasets)
2025-03-09	(same 11 datasets)

Per-Agent Source Files

Day	Agent	Files Accessed
2025-03-01	exfiltration	11 Zeek datasets
2025-03-01	initial_access	34936-sensor-250301-00002369_redacted.pcap
2025-03-01	lateral_movement	11 Zeek datasets
2025-03-01	payload	34936-sensor-250301-00002369_redacted.pcap
(same pattern for all 9 days)		

Days analysed: 2025-03-01, 2025-03-02, 2025-03-03, 2025-03-04, 2025-03-05, 2025-03-06, 2025-03-07, 2025-03-08, 2025-03-09